

ASSET: SYSTEM CORE

STATUS: MONITORING

Gestión de la Seguridad — Lección 02

Vectores de ataque y Triage inicial

PROPÓSITO: Aprender a reconocer por dónde ataca una amenaza, justificar la clasificación y proponer controles verificables.

Vocabulario esencial: anatomía de un incidente

Hecho

evento observable del escenario.

Vector

vía o mecanismo general utilizado.

Amenaza

actor, evento o circunstancia capaz de causar daño.

Superficie de Ataque

conjunto de puntos potenciales de entrada.

Vulnerabilidad / Condición

debilidad o situación que aumenta la exposición.

Activo

recurso con valor que debe protegerse.

Técnica

Comportamiento utilizado para lograr un objetivo.

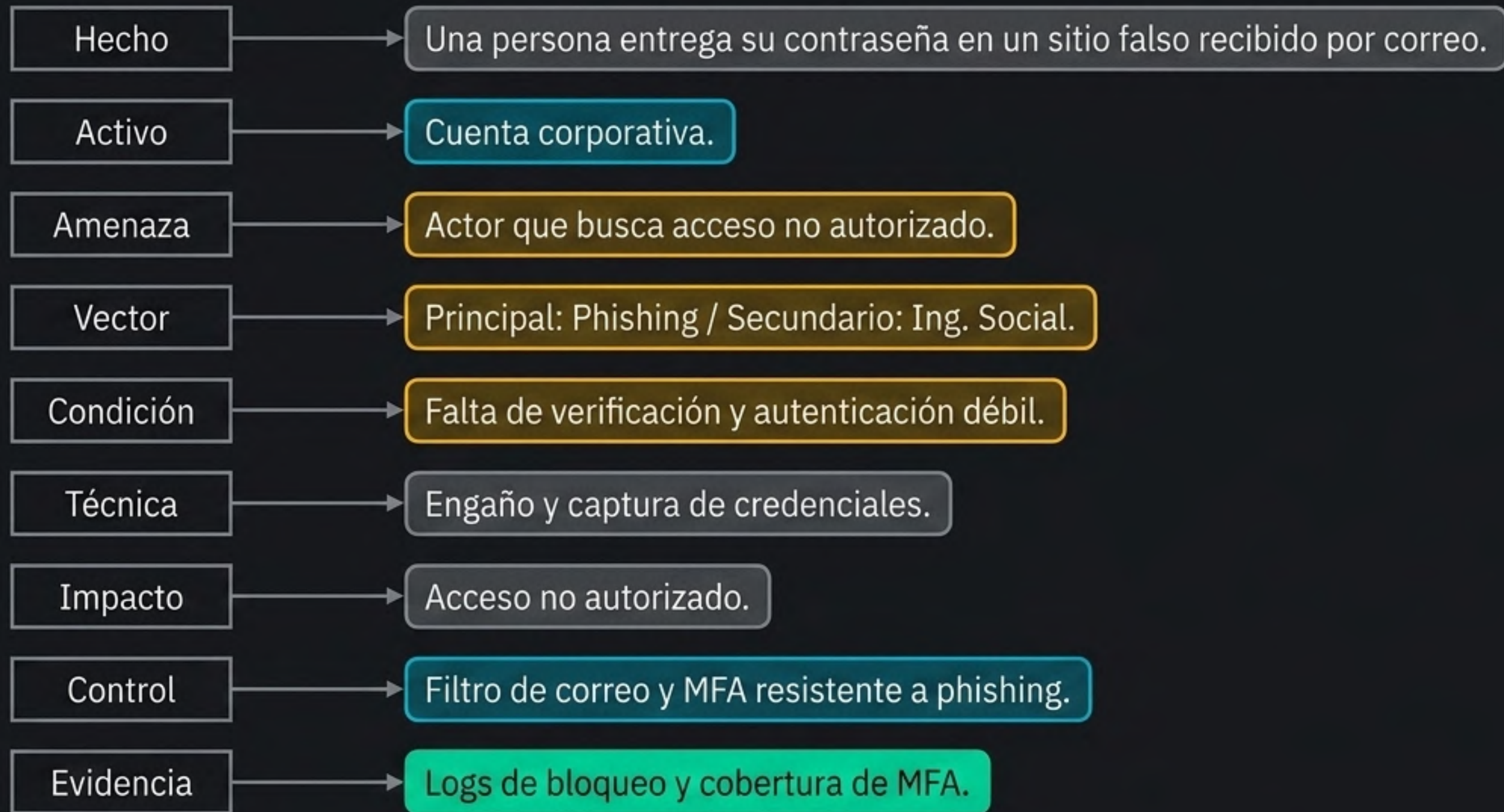
Exploit

Código o método que aprovecha una vulnerabilidad específica.

Impacto

consecuencia para la organización.

El Método de Análisis: Paso a Paso



Las etiquetas aisladas no sirven; la justificación debe basarse en hechos del escenario.

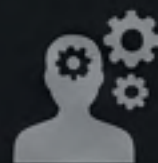
El Panorama: Los 13 Vectores de Ataque

01



Phishing

02



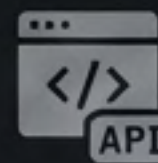
Ingeniería Social

03



Malware

04



Aplicaciones
Web / API

05



Credenciales

06



Servicios
Expuestos

07



Configuración
Insegura

08



Amenazas
Internas

09



Terceros / Cadena
de Suministro

10



Dispositivos
Móviles

11



Redes
Inalámbricas

12



Medios
Removibles

13



Ataques Físicos

⚠ Atención: Esta lista es una agrupación pedagógica del programa. No constituye una taxonomía oficial, universal ni cerrada.

El Factor Humano y de Identidad

Phishing



Señal: El engaño llega mediante un mensaje o servicio digital, usando urgencia o suplantación.

● **Condición:**
filtrado insuficiente, verificación débil o ausencia de MFA adecuado.

● **Control Inicial:**
Filtrado, autenticación de correo, MFA.

Ingeniería Social

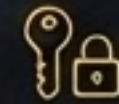


Señal:
Manipulación directa de personas o procesos.

● **Condición:**
Procesos informales, presión por rapidez.

● **Control Inicial:**
Procedimientos estrictos de identidad, doble aprobación.

Ataques a Credenciales



Señal:
Obtención, adivinación o abuso de contraseñas/sesiones.

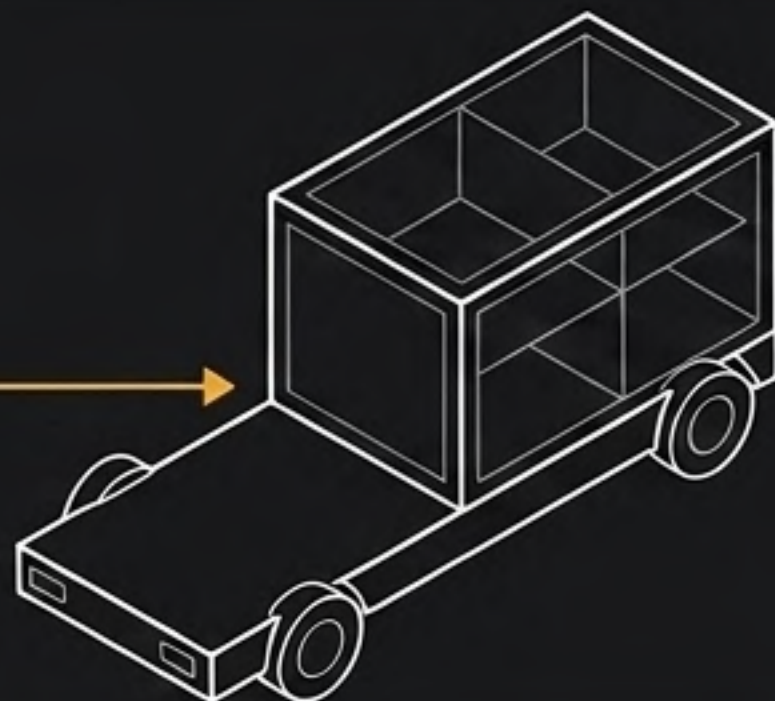
● **Condición:**
Reutilización de claves, falta de MFA.

● **Control Inicial:**
Gestores de contraseñas, detección adaptativa, rotación.

Malware y Medios Removibles: La Carga vs. La Vía

El Vehículo (Vía inicial)

El método por el cual llega la carga. Puede ser Phishing, Web, o un Medio Removible.



La Carga (Malware)

Código utilizado para ejecutar acciones, sabotear o extorsionar. Es la capacidad destructiva.



Panel: Medios Removibles (USB, Discos)

Ejemplo:

Pendrive desconocido conectado en recepción.



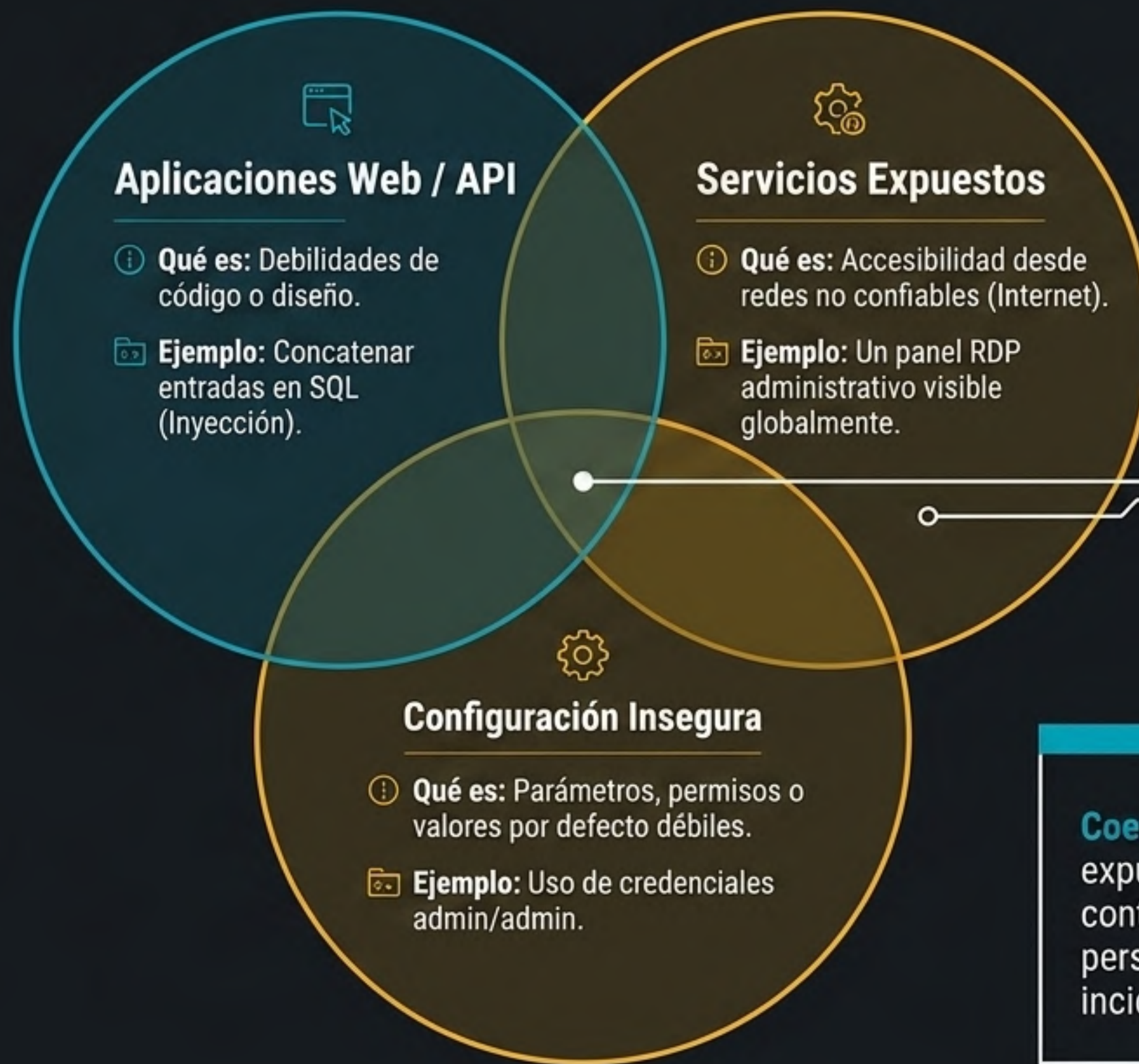
Condición:

Conexión automática habilitada, curiosidad inducida.



El malware puede ser la carga o capacidad utilizada; no necesariamente es la vía de entrada inicial.

El Perímetro Digital: Web, Servicios y Configuraciones



Coexistencia: Un servicio puede estar expuesto a Internet y además tener la contraseña por defecto. Son perspectivas diferentes de un mismo incidente.

El Riesgo de la Confianza: Internos y Cadena de Suministro



⚠ **Amenaza Interna (Acceso Directo Legítimo)**

Riesgos originados por cuentas con acceso autorizado (ej. Empleado copia datos a nube personal).

Condición: Privilegios excesivos, falta de segregación.

🔗 **Terceros (Acceso Indirecto Heredado)**

Dependencias que incorporan software o acceso (ej. Proveedor con cuenta comprometida).

Condición: Confianza implícita, contratos débiles.

⚠ Amenaza interna ≠ intención maliciosa. El incidente puede originarse por error, negligencia, abuso intencional o una cuenta legítima comprometida

Fronteras Extendidas: Móviles, Inalámbricas y Físicas



Dispositivos Móviles

⚠ Exposición: Llevan datos e identidad fuera del perímetro (ej. Tableta sin bloqueo extraviada en viaje).

● **Controles:** MDM, Cifrado, Borrado remoto.



Redes Inalámbricas

⚠ Exposición: Comunicaciones interceptables en el aire (ej. Wi-Fi corporativa falsa o clave compartida).

● **Controles:** Identidades individuales (802.1X), Segmentación.



Ataques Físicos

⚠ Exposición: Intervención de instalaciones o equipos físicos (ej. Visitante entra a sala de servidores).

● **Controles:** Zonas restringidas, control de visitas, protección de puertos.

La Realidad: Vectores Combinados

Incidente 01: El Pendrive de 'Sueldos'

Hecho:

Pendrives rotulados "Sueldos" abandonados en recepción instalan malware.

Vector Principal:

Medios Removibles (vehículo de transporte físico).

Vectores Secundarios:

Ingeniería Social (etiqueta induce curiosidad), Físico (ingreso al edificio), Malware (la carga).

Incidente 02: El Proveedor Hackeado

Hecho:

Atacante entra a la red usando el acceso remoto de un proveedor.

Vector Principal:

Terceros / Cadena de Suministro (relación habilitó el acceso).

Vector Secundario:

Ataques a Credenciales (abuso de identidad).

El vector principal describe la vía dominante inicial; el secundario añade el mecanismo facilitador. Justifícalo siempre con hechos.

De la Condición al Control: La Importancia de la Evidencia

Nombrar una herramienta no demuestra que funciona. El control debe reducir una condición concreta.

Medida	Control Declarado (Ilusión)	Evidencia Verificable (Realidad)
MFA	Está habilitado	Logs de validación y % de cobertura real.
Firewall	Captura de pantalla de una regla	Prueba de tráfico denegado/permitido.
Capacitación	Lista de asistencia firmada	Resultados de evaluación y reportes.
Respaldo	Existe un archivo de backup	Restauración probada exitosamente.
MDM	Aplicación instalada en el móvil	Estado de cumplimiento y prueba de bloqueo remoto.

OWASP

Propósito:

Lenguaje de riesgos Web/API.

Uso:

Orienta la comunicación sobre fallas de diseño/código (ej. Injection, Broken Access Control).



Advertencia Crítica: Asignar una categoría OWASP a un escenario NO demuestra que la vulnerabilidad exista; no reemplaza la revisión de código o la evidencia.

MITRE ATT&CK

Propósito:

Conocimiento de tácticas y técnicas basadas en observaciones reales.

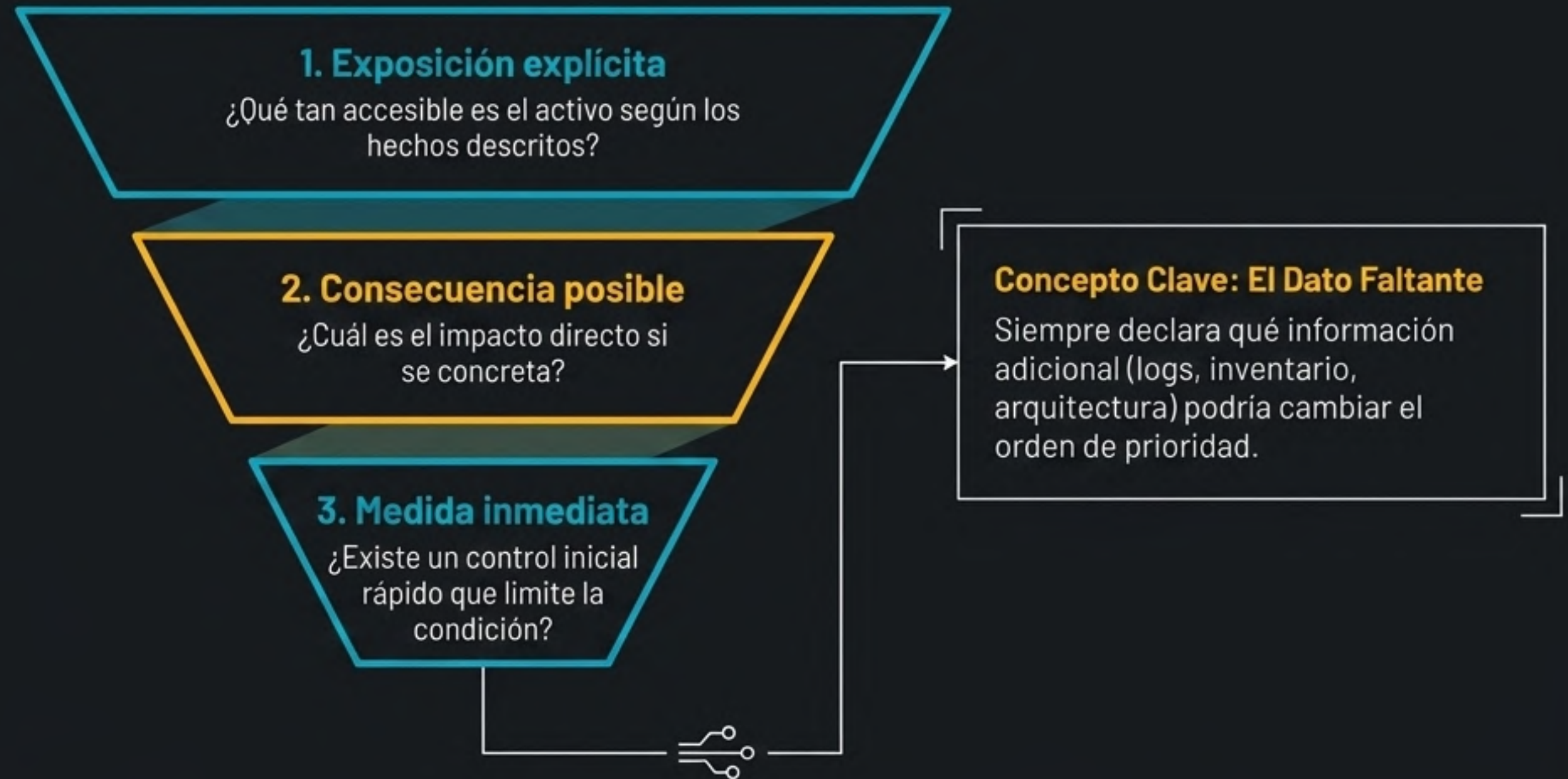
Uso:

Precisa el comportamiento del atacante (el Por qué y el Cómo).



Advertencia Crítica: No existe una correspondencia 1:1 exacta con los 13 vectores didácticos. No es una lista para memorizar.

Triage Inicial: Priorizando sin Matemáticas



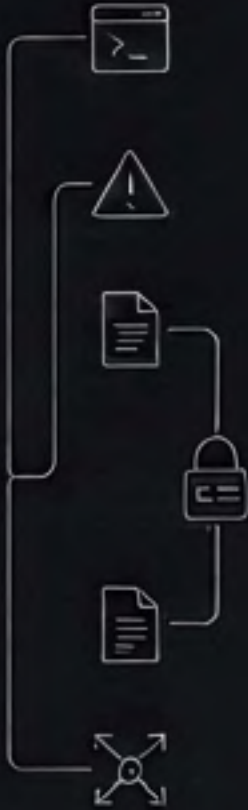
REGLAS DE ESTA FASE: **NO** usar matrices. **NO** usar cálculos numéricos de probabilidad. **NO** calcular riesgo residual o inherente (se estudiará en la Unidad 2).

Expediente de Análisis: Caso Guiado Integrador

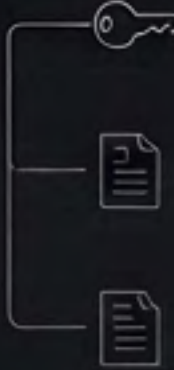
El Escenario

Un administrador reutiliza su contraseña corporativa en un foro externo de videojuegos. El foro es vulnerado. El atacante usa esa credencial filtrada para entrar a la VPN de la empresa, la cual no tiene doble factor.

Desglose del Analista



- Activo:** Red corporativa y accesos VPN.
- Amenaza:** Atacante externo.
- Vector Principal:** Ataques a Credenciales (Reutilización).
- Vector Secundario:** Servicios Expuestos (VPN).
- Condición:** Ausencia de MFA en perímetro.
- Impacto:** Acceso no autorizado a la red corporativa



- Control Inicial:** Habilitar MFA para la VPN.
- Evidencia verificable:** Logs de autenticación que demuestren el uso y cobertura de MFA.
- Prioridad de Triage:** Decisión de triage: atender primero por la exposición vía VPN, la posible consecuencia y la existencia de una medida inmediata.
- Dato Faltante:**

Síntesis y Autoevaluación

Cheat-Sheet (Tabla Resumen)

Data Tactical

Phishing: Mensaje/engaño directo.	Ing. Social: Manipulación de personas/procesos.	Malware: Ejecución de código (Suele ser la carga).	Web/API: Falla de código/diseño.	Credenciales: Abuso de identidad.
Serv. Expuesto: Accessible desde el exterior.	Config. Insegura: Parámetros débiles. (Pueden coexistir).	Interna: Acceso directo (No siempre malicioso).	Terceros: Acceso heredado/proveedor.	Dispositivos móviles: Compromiso de endpoint móvil.
Redes inalámbricas: Acceso/intercepción WiFi.	Medios removibles: Infección vía USB/disco externo.	Ataques físicos: Acceso directo a hardware/instalaciones.		

Errores Frecuentes (Compacto)

- ⚠ Vector ≠ vulnerabilidad.
- ⚠ Malware no siempre es la vía inicial.
- ⚠ Nombrar un control ≠ demostrar que funciona.

Preguntas de Autoevaluación

- ¿En qué se diferencian estrictamente un vector y una vulnerabilidad?
- ¿Por qué nombrar una herramienta (ej. Firewall) no es suficiente sin evidencia verificable?
- ¿Por qué una categoría OWASP no reemplaza la evidencia del caso?